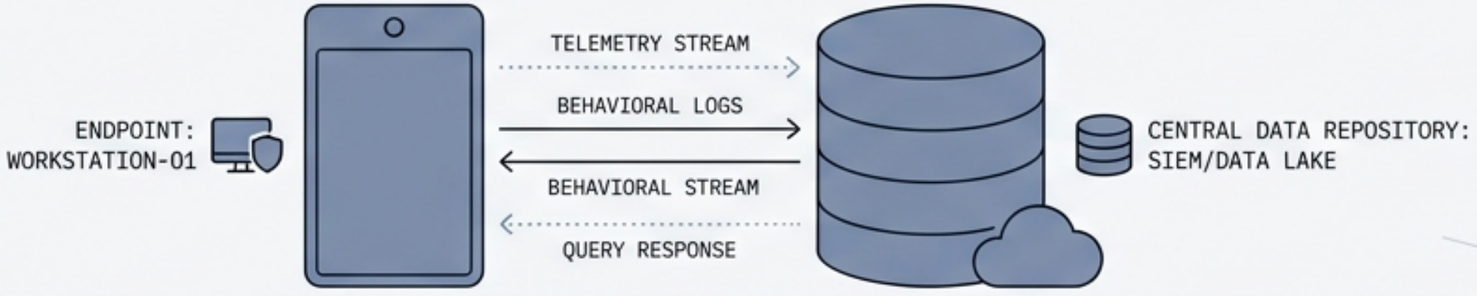
INSIDE A SECURITY OPERATIONS CENTRE (SOC)

EDR, Threat Detection & Early-Stage Cyberattacks



An educational and analytical breakdown of endpoint telemetry, detection engineering, and attack visibility.

Gemini Notebook

SOC Fundamentals & The Mission



Antivirus (AV)

Pillar: Prevention

Stops known bad files and signatures.

Fails against novel techniques and fileless attacks.

Limited Visibility

Endpoint Detection & Response (EDR)

Pillar: Detection & Response

Records system behaviour over time.

Catches unknown threats and living-off-the-land techniques.

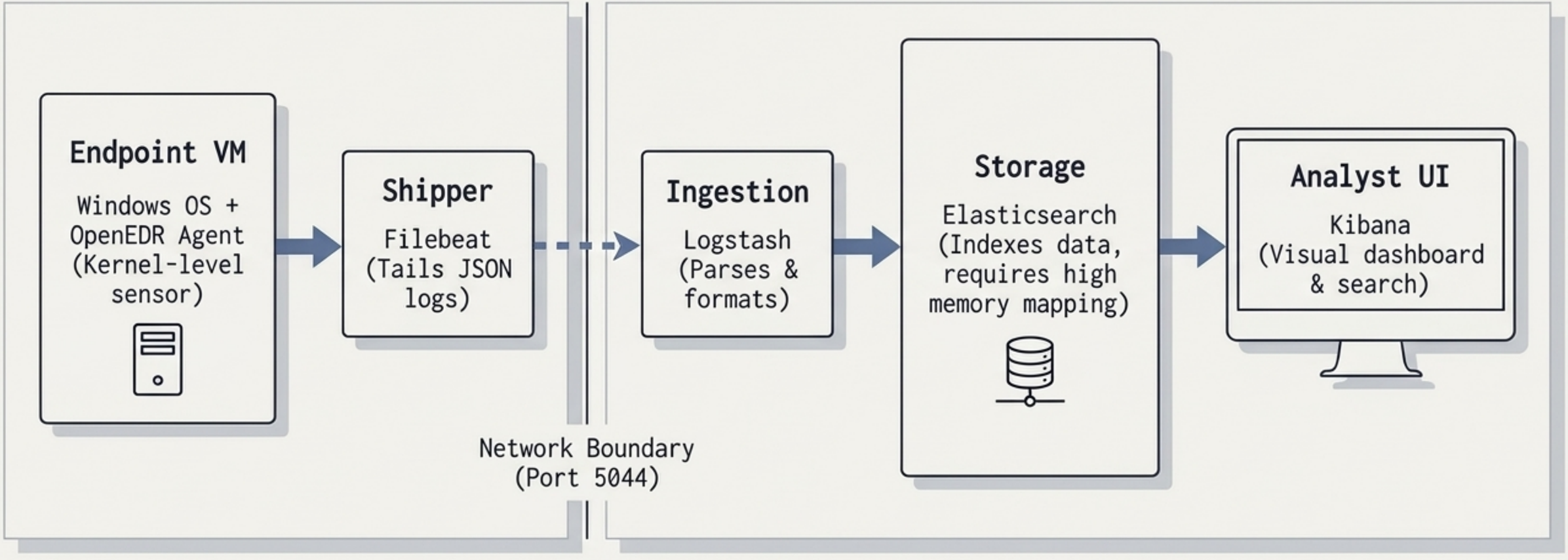
Full Behavioral Telemetry

Prevention Focus (AV) → Detection & Response Focus (EDR)

Comprehensive Posture

Gemini Notebook

Technology Architecture: Endpoint to Dashboard



Telemetry travels from local system execution to a centralized search cluster in milliseconds.

Gemini Notebook

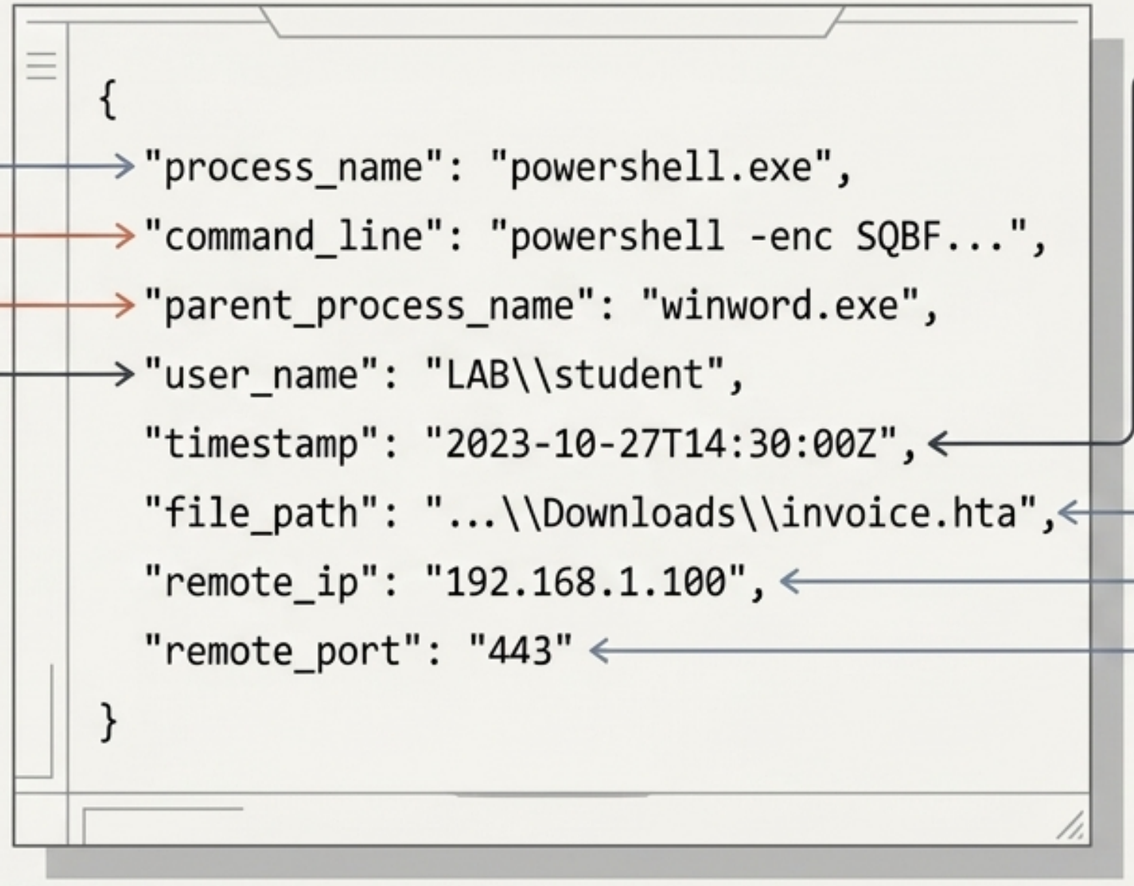
Understanding Telemetry: The DNA of an Alert

Process Name
What ran
`powershell.exe, nltest.exe`

Command Line
The intent — the richest signal by far
`powershell -enc SQBF...`

Parent Process
Who launched it
(the lie-detector for lures)
`winword.exe, explorer.exe`

User
Whose context it ran as
`LAB\\student`



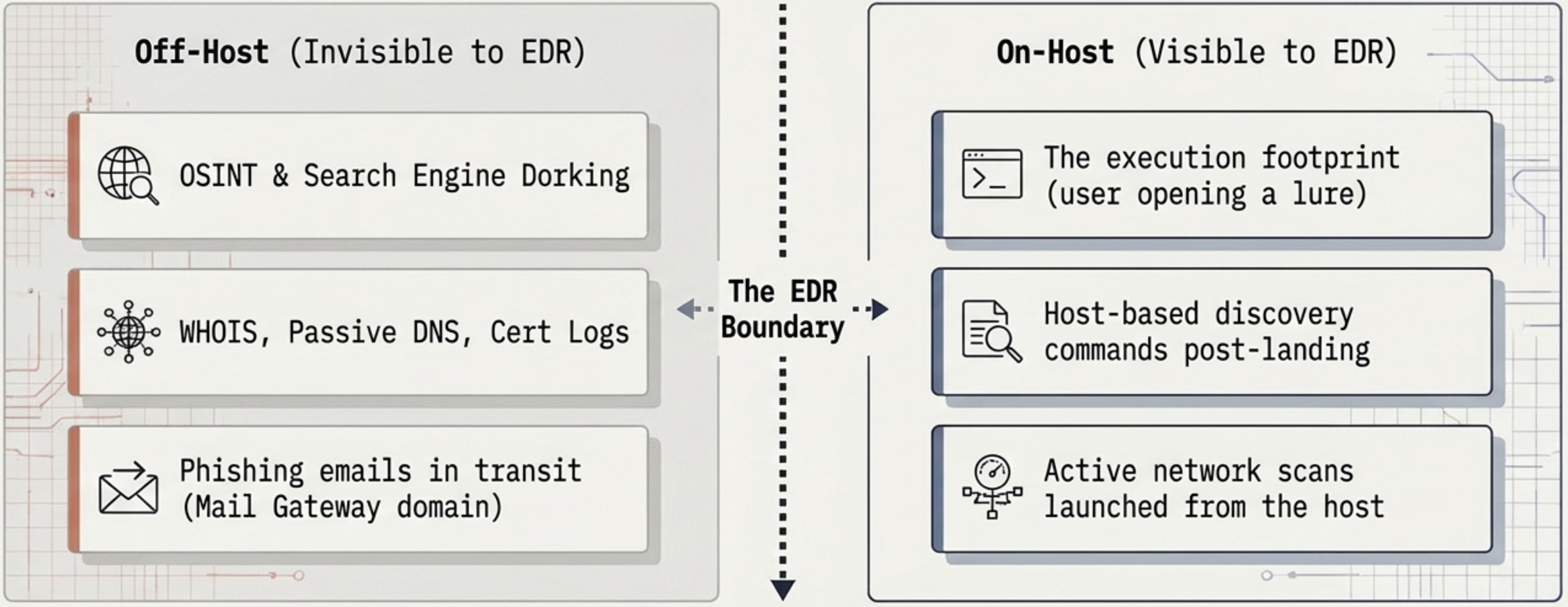
Timestamp
Ordering and bursts
`event time`

File path / operation
What was written or read
`...\\Downloads\\invoice.hta`

Network remote IP / port
Where a connection went
`192.168.1.100`
`443`

Gemini Notebook

The EDR Boundary: Early Attack Visibility

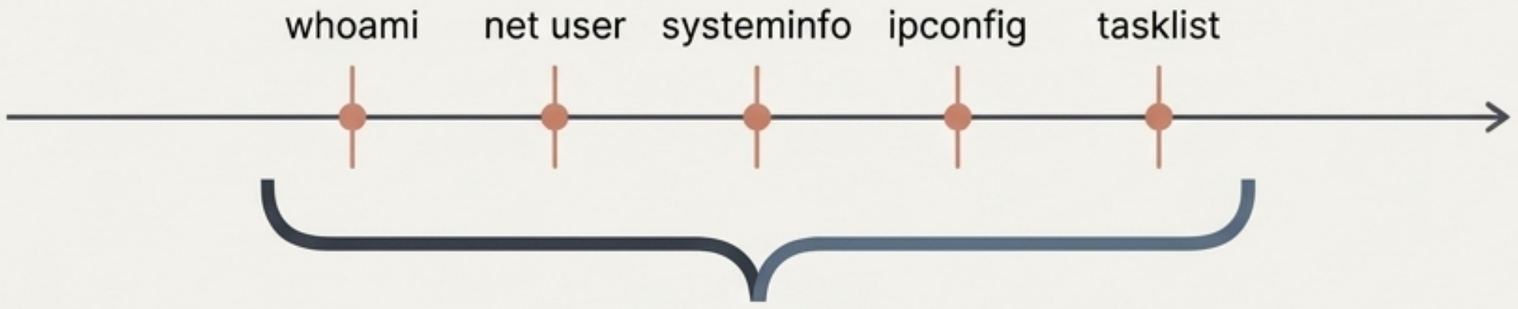


An endpoint sensor is completely blind to activity on attacker machines or third-party services.

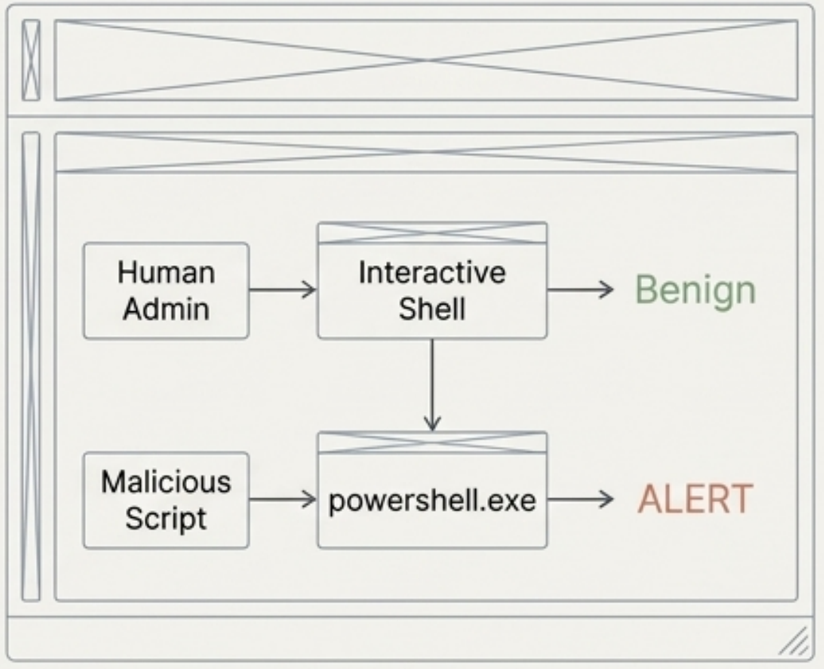
Detection begins at the exact moment the intrusion touches the endpoint OS and memory.

Gemini Notebook

Scenario R1: Host-Based Reconnaissance



Detection Logic: The Burst.
Threshold of 5+ distinct tools run by one user in < 5 minutes.

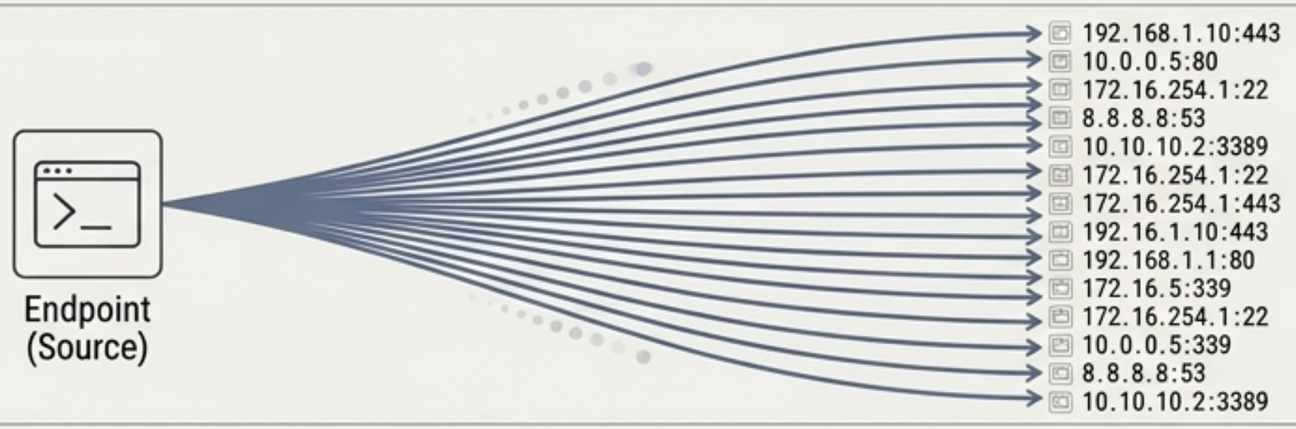


Objective:	Attacker orienting themselves post-compromise.
Telemetry:	Process creation events.
MITRE ATT&CK:	T1082 (System Info), T1087 (Account Discovery).
Limitation:	Requires strict time-thresholds and parent-process filters to avoid false positives from legitimate sysadmins.

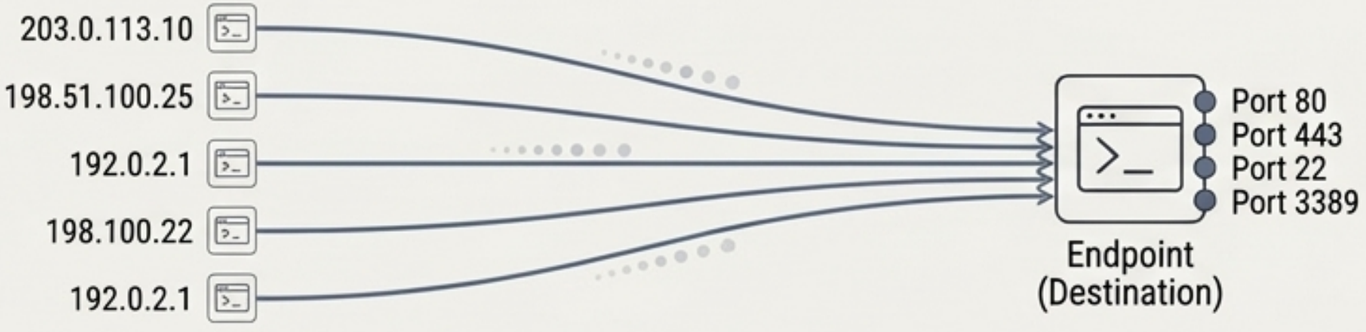
Gemini Notebook

Scenario R2: Network Scanning (The Endpoint View)

Outbound: One process touching 20+ distinct IP:Port pairs in < 1 minute.



Inbound: Many external IPs touching multiple local ports on this host.



Summary

Objective:
Identify network topography and vulnerable services.

Telemetry:
Network connection events.

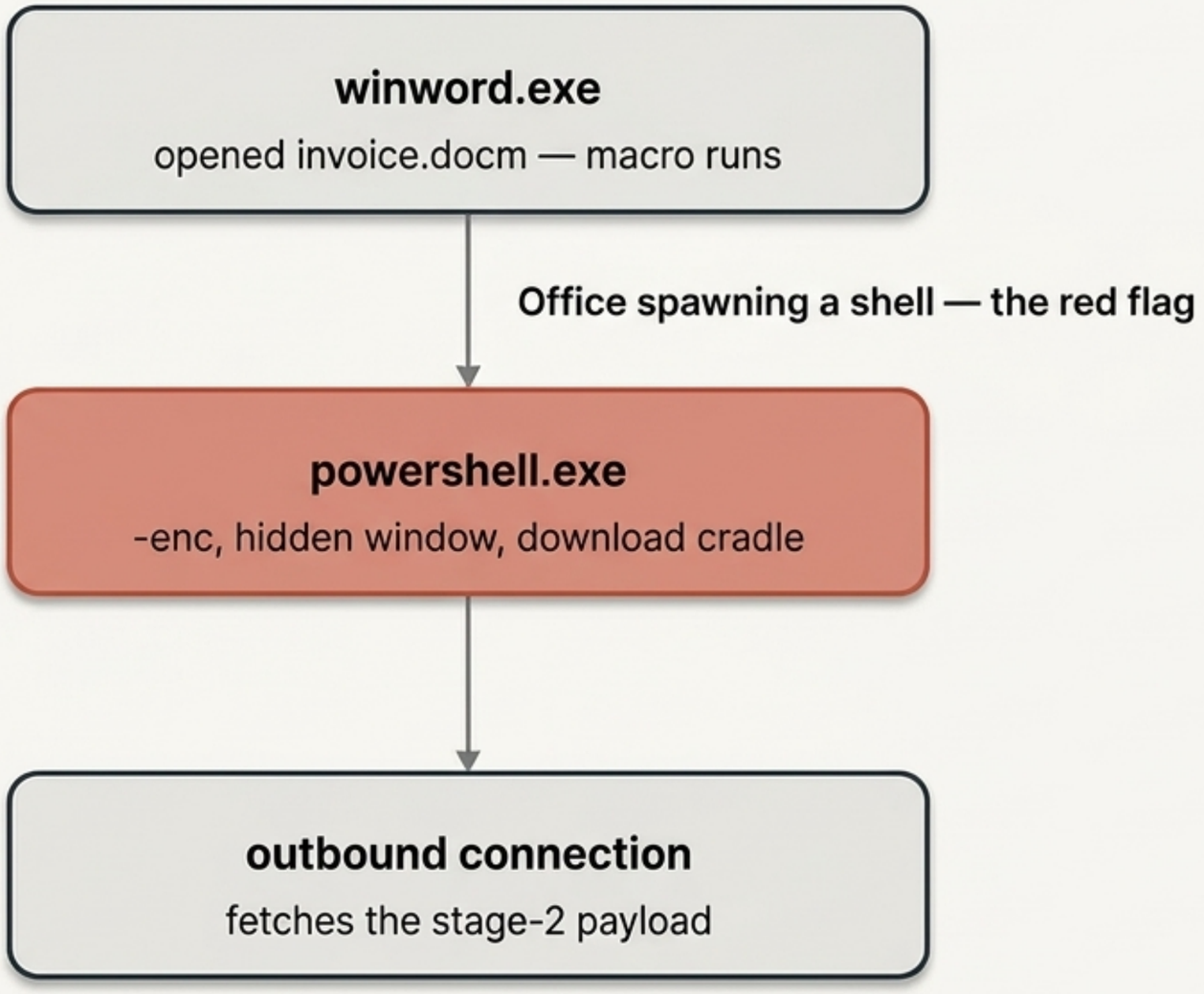
MITRE ATT&CK:
T1046 (Network Service Discovery).

The Honest Limit:
EDR has high confidence for scans touching this specific host, but is completely blind to scans occurring between other machines. Network-wide visibility requires an IDS.

Gemini Notebook

Scenario S1: The Weaponised Document

- **Objective**: Spearphishing attachment triggers malicious macro to pull payload.
- **Telemetry**: Process creation (Parent-Child anomaly).
- **Detection Logic**: Parent is an Office app AND child is a command interpreter.
- **MITRE ATT&CK:** T1566.001 (Spearphishing Attachment).
- **Fidelity:** Extremely high. Attackers can obfuscate commands, but cannot hide that Microsoft Word launched launched them. Zero threshold required.



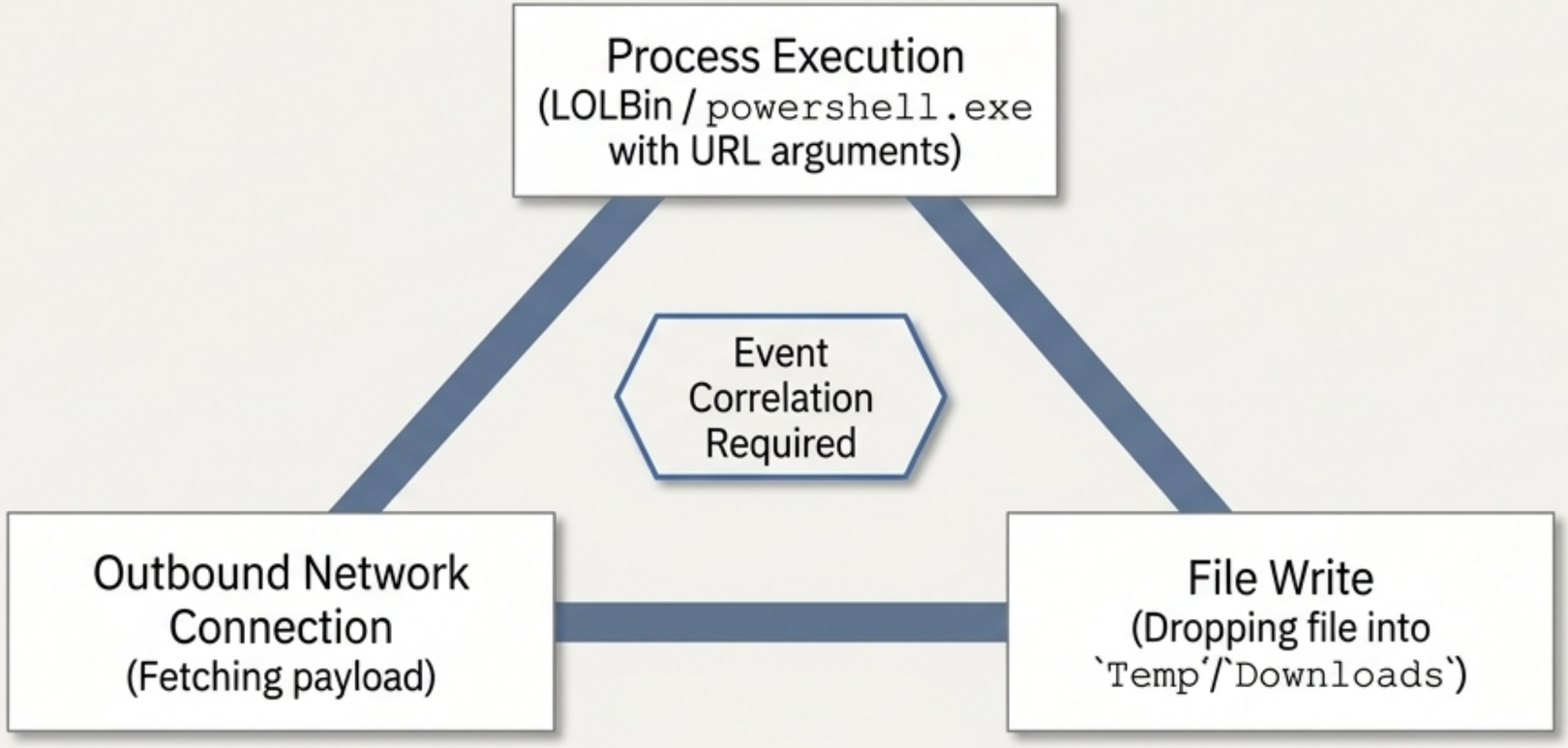
Gemini Notebook

Scenario S2: Phishing Links & Download Cradles

Summary

- **Objective**: Victim clicks a link; a cradle script downloads malware using Living-off-the-Land Binaries (mshta, regsvr32).
- **Telemetry**: Signed binaries launched with remote-fetch arguments (`Invoke-WebRequest`).
- **MITRE ATT&CK**: T1105 (Ingress Tool Transfer), T1218 (System Binary Proxy).

Correlation Triangle

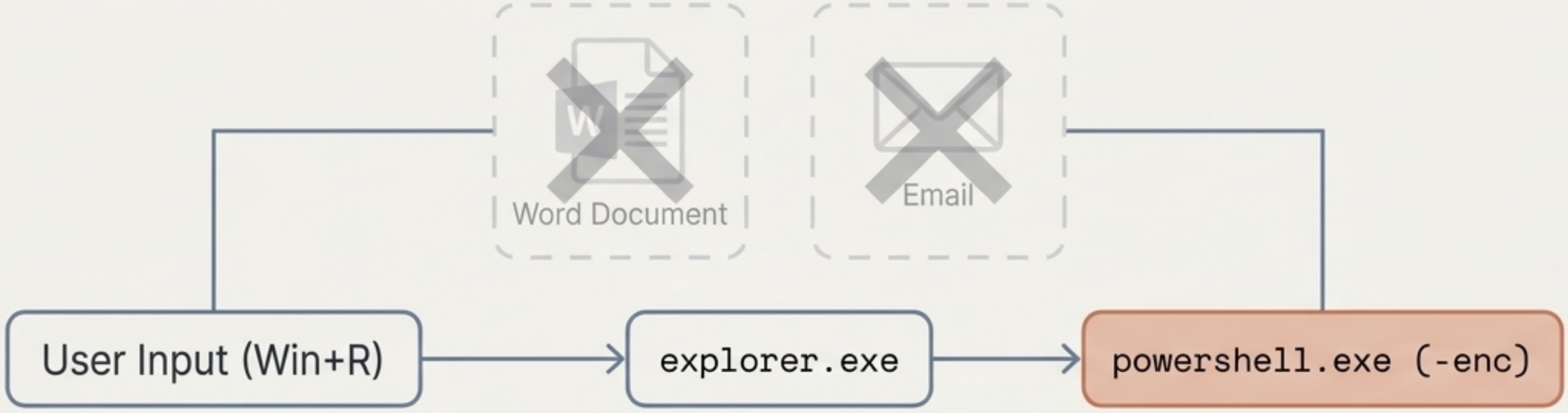


Detection Logic

LOLBins have legitimate uses. Analysts must correlate all three events (command + connection + file drop) to prove malicious intent and filter out benign noise.

Gemini Notebook

Scenario S3: Fake IT / ClickFix (Low-Artifact)



Left Column

- **Objective**: Social engineering bypasses technical controls by convincing the user to paste a malicious command directly.
- **Telemetry**: explorer.exe spawns a shell (Normal Windows behaviour).
- **MITRE ATT&CK**: T1204 (User Execution), T1059.001 (PowerShell).

Right Column

- **Detection Limitation**: The parent-child signal is useless here. Analysts rely entirely on spotting suspicious command-line intent (-enc, hidden, iex).
- **The Lesson**: Hardest to detect via EDR because it perfectly mimics human administration. Requires user-awareness training over technical detection.

Gemini Notebook

Detection Engineering & MITRE ATT&CK

Detection Engineering with KQL

```
process.parent.name : ("winword.exe" or "excel.exe")
  and process.name : ("powershell.exe" or "cmd.exe")
```

- Kibana Query Language (KQL) filters millions of benign logs.
- Boolean Logic: Uses AND (enforcing relationships) and OR (lists of suspicious binaries).
- Wildcards: Identifying dynamic intent (e.g., *http*).

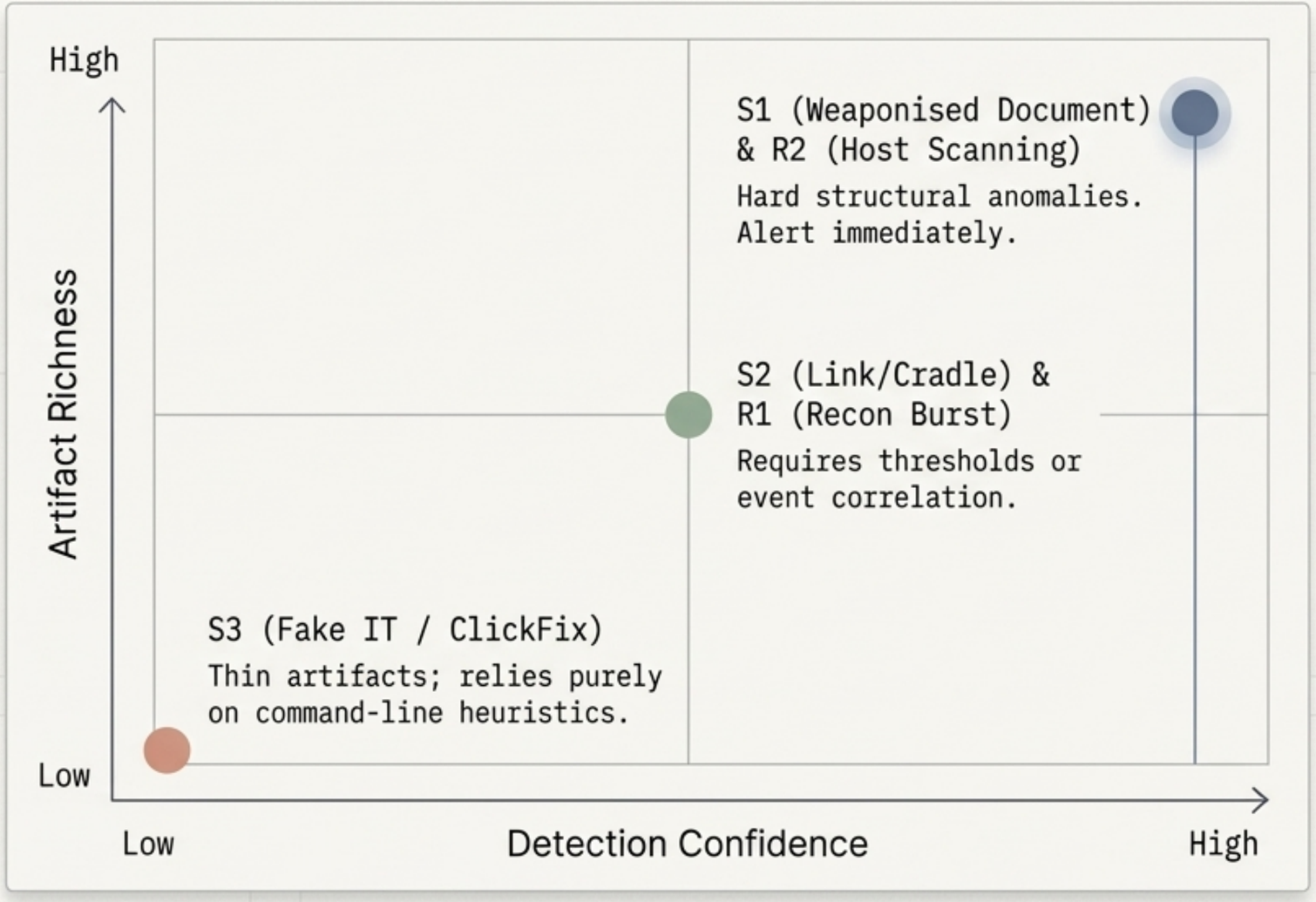
Mapping to MITRE ATT&CK

		Tactics			
		Initial Access	Execution	Persistence	Discovery
Techniques	...				
	...				
	Command and Scripting Interpreter		T1059.001 PowerShell		
	...				
	...				

- Why we map: Analysts standardize observed behaviours to measure defensive coverage.
- Tactics: The attacker's ultimate goal (e.g., Execution, Discovery).
- Techniques: How they achieve it (e.g., T1059.001 PowerShell).

Gemini Notebook

Detection Fidelity: The Synthesis Matrix



The Core Insight

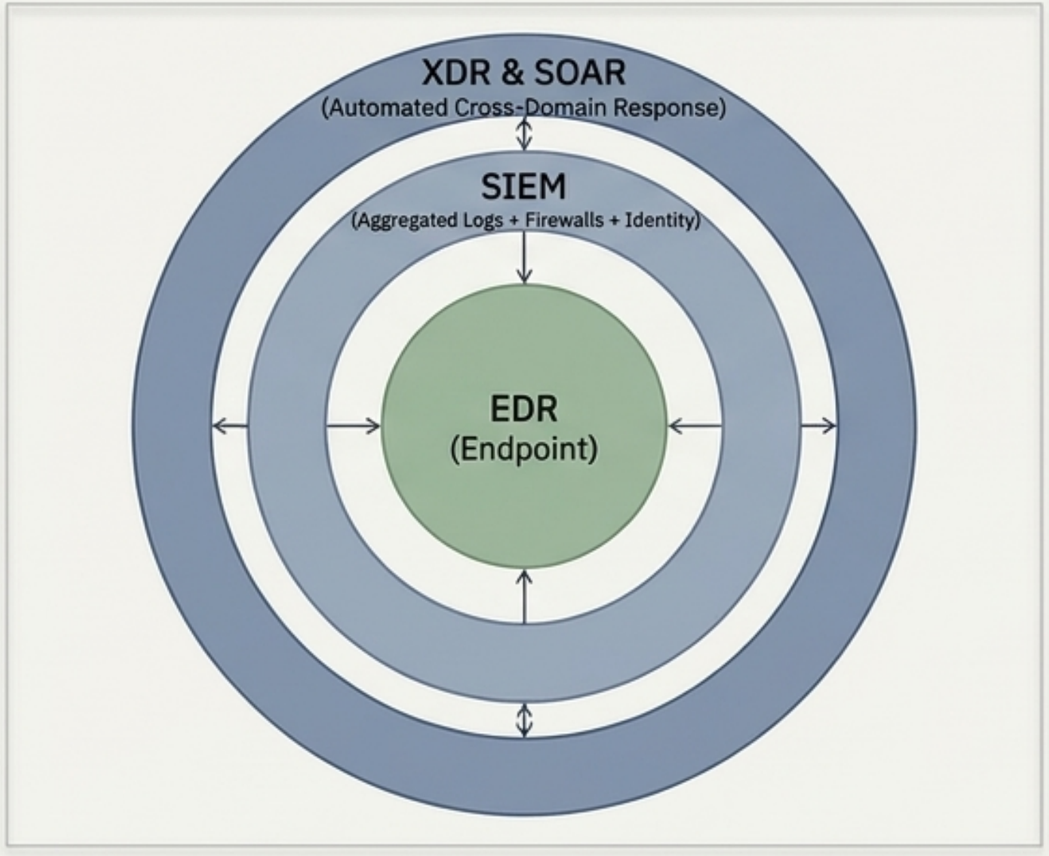
As social engineering strips away physical artifacts (attachments, files), endpoint detection gets thinner.

Attackers shift toward human manipulation precisely to evade these technical sensors.

Gemini Notebook

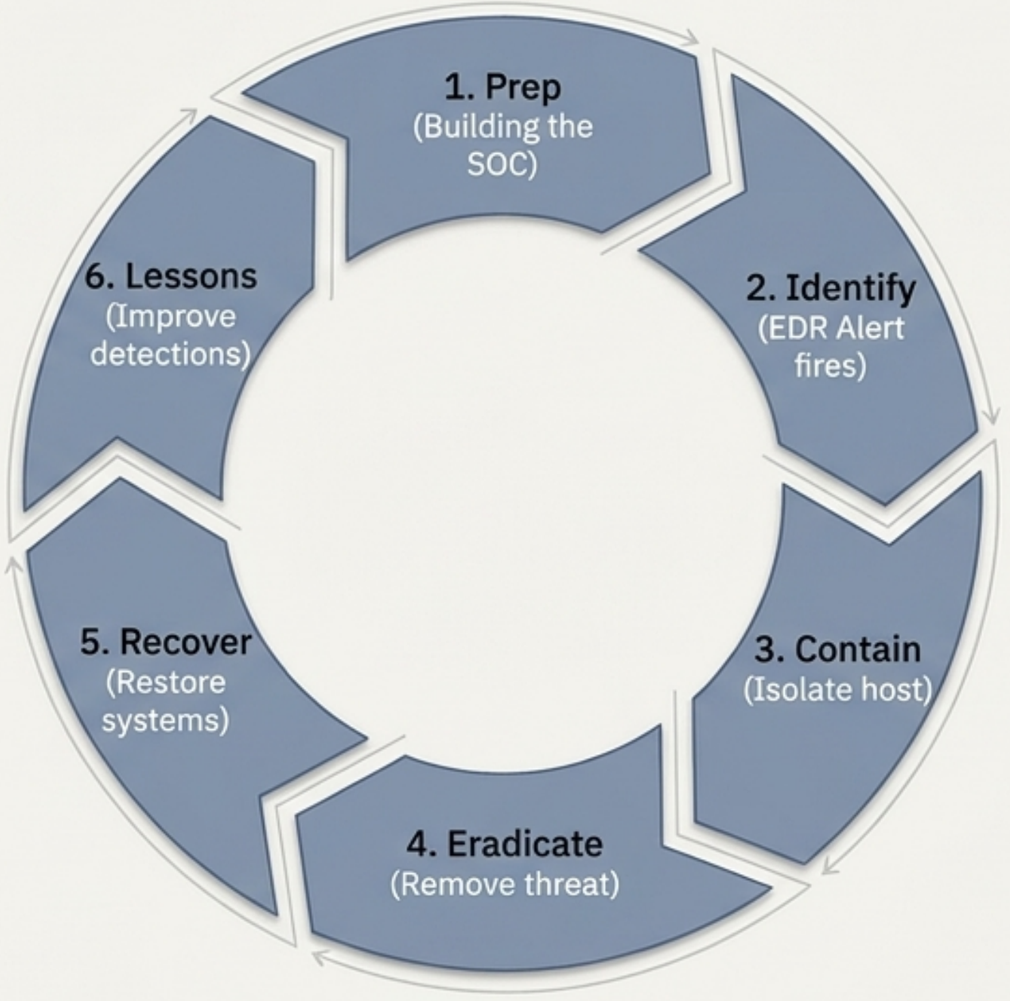
Beyond EDR & Incident Response

Architecture



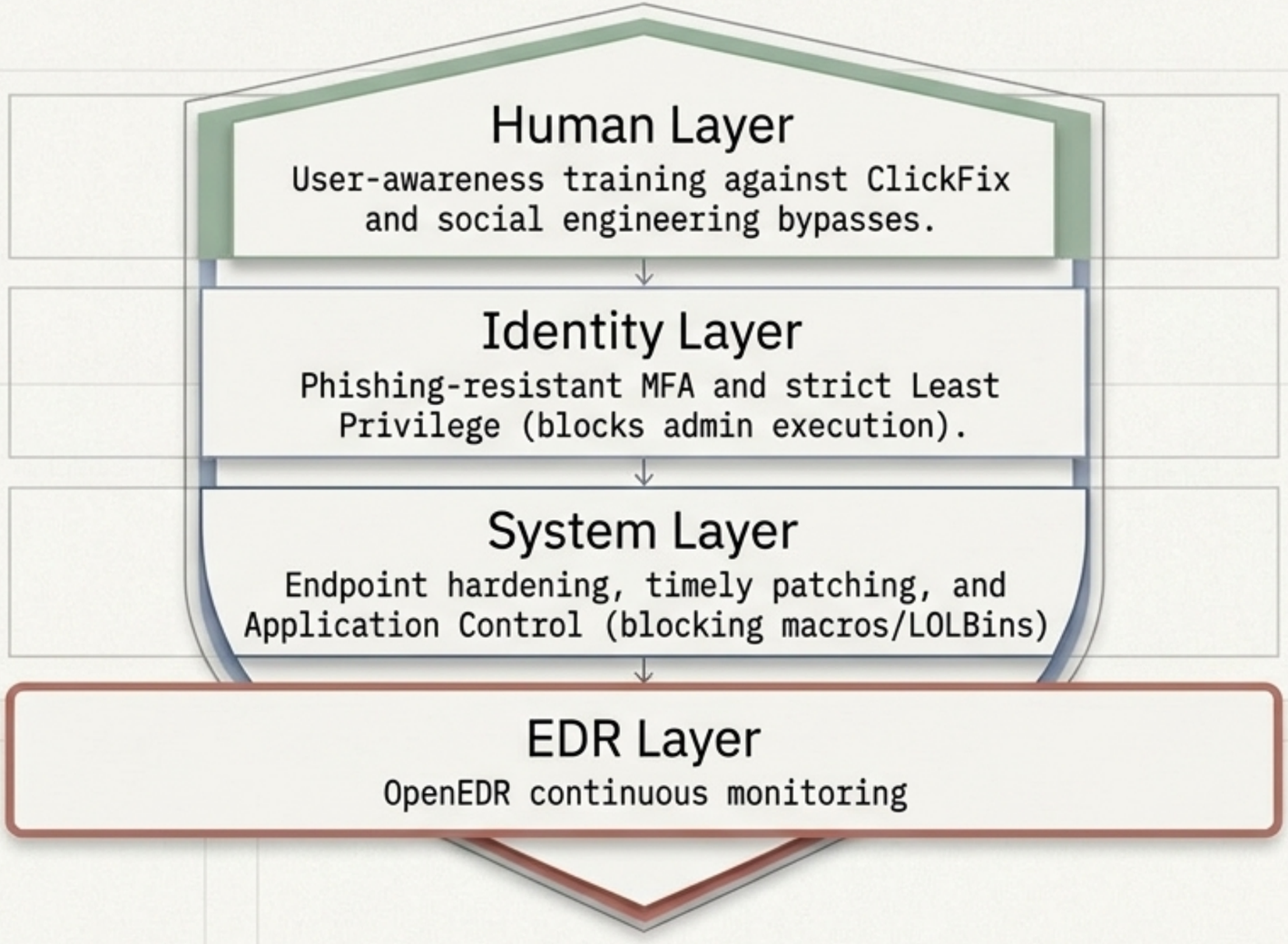
EDR is just one sensor. SIEM provides the global view, and SOAR automates the actions.

IR Lifecycle



Gemini Notebook

Defensive Strategies: Defense in Depth



The Principle:

If OpenEDR fires an alert, the attacker is already inside the machine.

We must build robust layers of prevention ahead of the detection layer.

Gemini Notebook

Knowledge Check: Test Your Analyst Instincts

Why is an EDR sensor completely blind to OSINT reconnaissance?

OSINT happens entirely off-host; EDR only monitors local system execution, memory, and host network stacks.

What is the absolute highest-fidelity indicator of a malicious macro?

The parent-child structural anomaly: a productivity application (like MS Word) spawning a command shell.

How do analysts separate an attacker running 'whoami' from a legitimate sysadmin?

By applying tight time thresholds (bursts of commands in seconds) and correlating against the parent process (scripts vs interactive shells).

Gemini Notebook